

PatchIQ-iA Security Analysis

Sample 05 — Unsafe YAML Loading Detection

1. Objective

The objective of this test is to evaluate whether PatchIQ-iA can detect unsafe YAML loading when user-controlled configuration data is passed to `yaml.load()`. The test uses a small configuration loader containing an intentionally unsafe YAML loading operation.

2. Input Code

The following Python code was submitted as part of the Pull Request. The code passes user-controlled input directly to `yaml.load()`.

```
import yaml

def load_configuration():
    print("Configuration Loader")
    print("-----")

    data = input("Enter YAML configuration: ")

    if not data:
        print("No configuration provided.")
        return

    try:
        # Vulnerable: user-controlled YAML is loaded unsafely
        config = yaml.load(data)

        print("Configuration loaded:")
        print(config)

    except Exception as error:
        print("Failed to load configuration:", error)

def main():
    load_configuration()

if __name__ == "__main__":
    main()
```

3. PatchIQ-iA Output

The following screenshot shows the actual security review generated by PatchIQ-iA for this Pull Request.

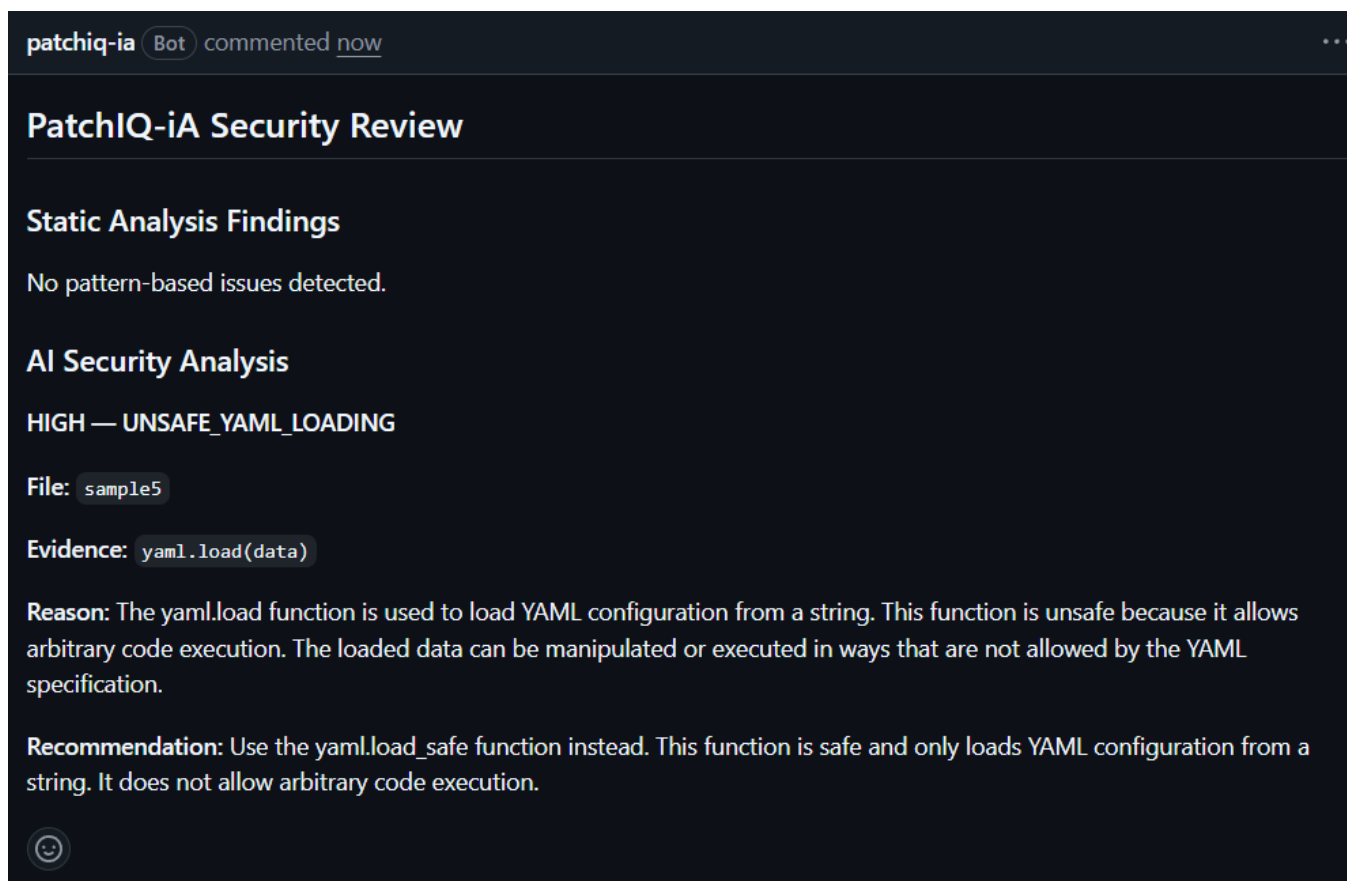


Figure 1. Actual PatchIQ-iA Security Review generated during the test.

4. Conclusion

PatchIQ-iA successfully detected the unsafe YAML loading pattern through AI security analysis. The finding was classified as HIGH severity, with evidence identifying `yaml.load(data)`. The analysis recognized the use of `yaml.load()` as unsafe and generated a recommendation to use the safer `yaml.safe_load()` function.